

Vault 2.0 vs Vault 1.21 Community Edition — A Self-Hosted Identity-Provider's Field Guide (Doc 3)

Scope note: This is the third document in the series. It assumes the technical depth of the prior two (Vault 1.21 CE as a self-hosted IdP on Docker Compose + Integrated Raft + Transit auto-unseal + TLS). All version/edition facts are anchored to primary HashiCorp/IBM sources (release notes, "Important changes," the GitHub CHANGELOG, IBM security bulletins) and flagged where unverifiable.

TL;DR

- **Vault 2.0.0 is real and shipped GA on April 14, 2026** (CE + Enterprise), and the jump from 1.21 → 2.0 is an *IBM lifecycle-versioning rebrand, not an architectural rewrite* — for a CE self-hoster it is functionally "Vault 1.22" with a pile of security-hardening breaking changes. The single most important fact: **the headline new features (AI-agent OAuth resource server, SCIM, SPIFFE JWT-SVID, Secret Sync WIF, visual policy generator) are all Enterprise and/or Beta — essentially nothing new in the marquee list is free CE**, while several real breaking changes (container IPC_LOCK/mlock, authenticated rekey/generate-root endpoints, canonical-path enforcement, no wildcards in templated policies) *do* hit CE and *will* affect your Docker Compose + OIDC stack.
- **The upgrade is a supported direct in-place hop from 1.21.x → 2.0.x (no intermediate version required), but it is not auto-rollback-able** and the container capability model changed three times across 2.0.0/2.0.1/2.0.2 — pin a specific patch (recommend **2.0.3**, June 17 2026, which also re-fixes the LIST-trailing-slash deny) and set `disable_mlock = true`.
- **Your OIDC/JWT IdP workflows keep working unchanged on CE**, plus you gain a genuinely useful CE improvement: the JWT/OIDC plugin's **multi-JWKS key-ID cache** and the Entra `fetch_groups` via Graph API path that bypasses the 200-group token overage. The thing to test before upgrading: any **templated ACL policy that renders a wildcard/glob** (now denied), any client hitting **non-canonical paths** (now redirected), and your **Transit auto-unseal recovery-key** rekey automation.

Key Findings

1. **Vault 2.0.0 GA = April 14, 2026** (preview April 1; the HashiCorp Enterprise 2.0 GA announcement blog is dated April 13, 2026: "Vault Enterprise 2.0 is now generally available"). Released together with Enterprise 2.0.0 and Enterprise patch lines 1.21.5, 1.20.10, 1.19.16. CE patch timeline so far: 2.0.0 → **2.0.1 (CE released 2026-05-19, with limited CE artifacts — HashiCorp advised waiting for 2.0.2)** → 2.0.2 (June 5 2026) → 2.0.3 (June 17 2026). CE binaries exist for all four. [HashiCorp Discuss](#)
2. **Why "2.0":** IBM completed the HashiCorp acquisition on **Feb 27, 2025** (all-cash, \$35/share, ~\$6.4B enterprise value, per IBM Newsroom). Self-managed products moved to IBM's

Support Cycle-2 (SC2) model starting the April 2026 release. SC2 maps HashiCorp's X.Y.Z to IBM's V.M.F and gives each major ("V") release **≥2 years standard support, a 3rd year of extended support (critical fixes + select security updates only), and years 4–6 of usage guidance**. HashiCorp's prior LTS designations are retired. [HashiCorp Help Center](#)

[HashiCorp Help Center](#)

3. **License unchanged:** Vault remains BSL 1.1 (source-available, converts to MPL 2.0 after 4 years) — *not* OSI open-source. 2.0 does not change this.
4. **The marquee 2.0 features are Enterprise/Beta, not CE:** SCIM 2.0 (Beta/Enterprise), AI-agent support + OAuth resource server (Beta/Enterprise), SPIFFE JWT-SVID (Enterprise), Secret Sync WIF (Enterprise), PKI External CA/ACME (Enterprise), visual policy generator + namespace wizard (Enterprise UI), rotation policies & LDAP self-managed static roles (Enterprise). The deprecation table for 2.0.0 is literally "None / None." [hashicorp](#)
5. **The breaking changes that hit CE (your stack):** container [cap_ipc_lock](#) removed at build time → must set [disable_mlock = true](#); [sys/rekey](#), [sys/generate-root](#), DR generate-operation-token now require a Vault token by default (fixes HCSEC-2026-08/CVE-2026-5807); non-canonical paths rejected then redirected; **wildcards/globs banned in rendered identity-template policy paths**; RSA modulus capped at 8192 bits (2.0.2+); LIST-with-trailing-slash deny correctly enforced (re-fixed in 2.0.3).
6. **OIDC/JWT auth is CE and unchanged in shape**, with CE improvements: [auth/jwt](#) plugin bumped to v0.26.1, multi-JWKS key-ID cache, and Entra [provider_config](#) [fetch_groups](#)/[distributed_claim_access_token](#) for >200-group overage. Vault-as-OIDC-provider ([identity/oidc/*](#)), RS256 JWTs) remains CE. [githubusercontent](#)
7. **Upgrade path:** direct 1.21.x → 2.0.x in-place upgrade is supported; no intermediate hop; no documented hard minimum version; **no dedicated "Upgrade to 2.0.x" page exists** (guidance consolidated into "Important changes"). Autopilot *automated* upgrades remain Enterprise-only — a CE Docker Compose user does a manual binary swap + unseal.

Edition & Version Legend

- **CE** = Community Edition (free, BSL 1.1, what you run)
 - **ENT** = Enterprise (license required)
 - **BETA** = beta-quality, discouraged in production
-

Feature-by-Feature Comparison Matrix

Feature	Vault 1.21	Vault 2.0	Version landed	Notes / breaking
Core secrets/auth engine, KV v1/v2, Transit, PKI, Raft, Transit auto-unseal	CE	CE	pre-1.21	No change; same APIs
OIDC auth method (<code>auth/oidc</code>)	CE	CE	pre-1.21	Unchanged shape; plugin → v0.26
JWT auth (<code>auth/jwt</code>)	CE	CE	pre-1.21	Multi-JWKS key-ID cache NEW in 2.0 CE
Vault as OIDC provider (<code>identity/oidc</code> , RS256 JWTs)	CE	CE	pre-1.21	Unchanged; powers your React/FastAPI SSO
Entra <code>fetch_groups</code> (Graph API, >200-group coverage)	CE	CE	1.21-era plugin	<code>provider_config.fetch_group</code> <code>distributed_claim_access_to</code>
ACL policies / templated policies	CE	CE	pre-1.21	BREAKING: wildcards/globs in <i>rendered</i> template output now de (2.0.0)
New ACL capability <code>recover</code>	CE	CE	1.21	Snapshot-recover authorization capability
<code>subscribe</code> capability + event subscriptions	CE	CE	1.16+	Event notifications CE; cross-clus forwarding ENT
LIST-with-trailing-slash deny fix	CE (1.21.x)	CE	re-fixed 2.0.3	More-specific deny now respected <code>LIST kv/private/</code>
Non-canonical path handling	reject (1.21.x)	redirect (2.0.0)	2.0.0	<code>//</code> , <code>/./</code> , <code>/../</code> cleaned/redirected
<code>disable_mlock</code> required w/ Raft	CE	CE	1.21	Now effectively mandatory in containers
Container <code>cap_ipc_lock</code> at build time	toggled 1.21.6/1.21.7	removed 2.0.2	2.0.0→2.0.2	Capability model changed 3× across patches

Feature	Vault 1.21	Vault 2.0	Version landed	Notes / breaking
Authenticated <code>sys/rekey</code> , <code>sys/generate-root</code> , DR token	unauth (≤1.21.4)	authenticated	2.0.0	Fixes CVE-2026-5807; <code>enable_unauthenticated_access</code> opt-out
Azure auth config precedence over <code>AZURE_*</code> env	env wins	config wins	2.0.0	Breaking for env-var-driven Azure auth
RSA modulus ≤ 8192 bits	unbounded	capped	2.0.2	CVE-2026-39829
<code>max_token_header_size</code> listener option	—	CE	2.0.0	Default 8 KB; set <code>-1</code> to disable; D hardening
AI-agent registry + OAuth resource server (RAR)	—	BETA/ENT	2.0.0	OAuth 2.0 JWT → direct authz, no Vault token
SCIM 2.0 server (entities/groups/aliases)	—	BETA/ENT	2.0.0	Okta/SailPoint provisioning
SPIFFE JWT-SVID issuance	—	ENT	2.0.0	<code>secrets/spiffe</code>
Secret Sync via Workload Identity Federation	— (sync ENT 1.x)	ENT	2.0.0	WIF removes static cloud creds
PKI External CA (ACME to public CAs) <code>githubusercontent</code>	—	ENT	2.0.0	New plugin
OS/local-accounts secrets engine (Linux rotation)	—	ENT	2.0.0	<code>secrets/os</code>
Rotation policies / LDAP self-managed static roles	—	ENT	2.0.0	Central Rotation Manager
Visual policy generator / namespace wizard (UI)	—	ENT (UI)	2.0.0	CE gets "intro" onboarding pages only
Vault MCP server (separate binary)	BETA (2025)	BETA	2025+	Works against CE; uses a normal Vault token
Namespaces	ENT	ENT	—	Still Enterprise (OpenBao has it fr

Feature	Vault 1.21	Vault 2.0	Version landed	Notes / breaking
Automated Raft autopilot upgrades	ENT	ENT	1.11	CE does manual upgrades
Automated snapshots	ENT	ENT	—	CE uses manual <code>raft snapshot save</code>

Details

1. What "Vault 2.0" actually is (and isn't)

The leap from 1.21 to 2.0 is **administrative, not architectural**. After IBM completed its HashiCorp acquisition (Feb 27, 2025 — all-cash, \$35/share, ~\$6.4B), all self-managed HashiCorp Enterprise products adopted IBM's Support Cycle-2 (SC2) lifecycle beginning with the April 2026 release wave; the X.Y.Z scheme is mapped onto IBM's Version-Modification-Fix (V.M.F) model, where a "V" bump (1.21 → 2.0) simply marks the start of a new support lifecycle. SC2 guarantees ≥2 years standard support per major release, a 3rd year of extended support (critical bug fixes + select security updates only), and years 4–6 of usage guidance. HashiCorp's old LTS designations are retired. InfoQ and the HashiCorp Enterprise 2.0 blog both confirm this is "the first major version number change since 1.0 (2018)" and that it "does not reflect a significant change in Vault architecture." `InfoQ` `HashiCorp`

Practical implication for you: treat 2.0 like you would have treated a "1.22" release — same Raft, same seal model, same API surface — but read the breaking-changes list carefully because this release bundles several deferred security-hardening changes.

License is unchanged: Vault stays **BSL 1.1** (source-available; each release converts to MPL 2.0 four years later). This is *not* OSI open-source, and 2.0 doesn't alter that — the key reason OpenBao (MPL-2.0 fork from Vault 1.14) remains the relevant truly-open CE alternative.

2. Releases & security context

- 2.0.0** — April 14, 2026 (GA; preview April 1; GA blog dated April 13). One breaking change in core (`sdk/helpers/docker`) migration from `docker/docker` to `moby/moby`, resolving GHSA-x744-4wpc-v9h2/GHSA-pxq6-2prw-chj9), Go bumped to 1.26.2, plus the security-hardening changes below. `githubusercontent` `githubusercontent`
- 2.0.1** — CE released 2026-05-19 (limited CE artifacts; HashiCorp advised waiting for 2.0.2). Container image now *requires* `IPC_LOCK` (set at build time; runs as unprivileged `vault` user).

- **2.0.2** — June 5, 2026. **Breaking:** `cap_ipc_lock` removed at build time so Vault runs in common container runtimes; Vault in containers can no longer `mlock()`, so **operators must set** `disable_mlock = true`. Also RSA ≤8192-bit cap (CVE-2026-39829); Go 1.26.4. (GitHub) (GitHub)
- **2.0.3** — June 17, 2026. Re-fixes the **LIST ACL bypass** (trailing-slash deny), adds constant-time recovery-token comparison, `auth/radius` `case_insensitive_names`. (GitHub)

Security driver for the headline auth change: HCSEC-2026-08 / **CVE-2026-5807** (CVSS 7.5) — an unauthenticated attacker could repeatedly initiate/cancel `sys/rekey`, `sys/generate-root`, and `sys/rekey-recovery-key` operations, occupying the single in-progress slot and blocking legitimate operators. Affected **Vault CE up to 1.21.4** and Enterprise up to 1.21.4/1.20.9/1.19.15; **fixed only in 2.0.0 with no 1.x CE backport** (Enterprise got 1.21.5/1.20.10/1.19.16). This is the architectural fix: those endpoint families now require a valid Vault token. A related KVV2 glob-delete DoS (HCSEC-2026-05) was also fixed in 2.0.0 (CE) / 1.21.5 (ENT). (IBM + 3)

3. OIDC auth method & JWT auth (HEAVY — your core use case)

Status: CE → CE, **unchanged in shape**. Everything you do today — brokering Entra ID OIDC logins via `auth/oidc`, validating JWTs via `auth/jwt`, and acting as your own OIDC provider issuing RS256 JWTs via `identity/oidc/*` — remains Community Edition in 2.0. The `auth/jwt` plugin was updated to v0.26.1 in 2.0.0. (githubusercontent)

CE improvements you gain in 2.0:

- **Multi-JWKS key-ID (kid) cache:** when a role uses multiple JWKS URLs (`jwtks_pairs`), Vault checks all in-memory caches for the token's `kid` before any network call; remote JWKS endpoints are only re-fetched on cache miss (e.g., after key rotation). This reduces login latency and JWKS endpoint load for your agentic workloads doing many logins. (HashiCorp Developer)
- **Entra group-coverage handling** (1.21-era plugin, carried into 2.0): `provider_config` with `provider=azure` plus `fetch_groups=true` fetches groups directly from the Microsoft Graph `me/getMemberObjects` endpoint — bypassing **both** the 200-group token limit *and* the per-app 1,000-group assignment limit. For the JWT login flow this requires passing a `distributed_claim_access_token` so Vault can call Graph. (HashiCorp Developer) (HashiCorp Developer)

Azure/Entra config (before → after) — note the precedence breaking change:

```
hcl

# auth/azure/config (the AZURE auth METHOD, not OIDC) — 2.0.0 BREAKING:
# values in auth/azure/config now take precedence over AZURE_* env vars.
# If you relied on env vars overriding stored config, that no longer works.
```

For OIDC (your actual path), config is unchanged. Reference working config:

```
bash

# OIDC method config – identical on 1.21 CE and 2.0 CE
vault write auth/oidc/config \
  oidc_discovery_url="https://login.microsoftonline.com/<tenant_id>/v2.0" \
  oidc_client_id="<app_client_id>" \
  oidc_client_secret="<client_secret>" \
  default_role="reader"

# Entra group overage via Graph (CE):
vault write auth/oidc/config - <<EOF
{
  "oidc_client_id": "<id>",
  "oidc_client_secret": "<secret>",
  "oidc_discovery_url": "https://login.microsoftonline.com/<tenant_id>/v2.0",
  "default_role": "reader",
  "provider_config": { "provider": "azure", "fetch_groups": true }
}
EOF

vault write auth/oidc/role/reader \
  user_claim="sub" \
  groups_claim="groups" \
  bound_audiences="<app_client_id>" \
  oidc_scopes="https://graph.microsoft.com/.default profile" \
  allowed_redirect_uris="https://vault.example.com:8200/ui/vault/auth/oidc/oidc/callback" \
  allowed_redirect_uris="http://localhost:8250/oidc/callback" \
  policies="reader"
```

bound_claims, **bound_audiences**, **distributed/overage claims**: unchanged semantics. Recall the 1.17+ rule (still in force): if the JWT carries an **aud**, the role's **bound_audiences** must exactly match at least one **aud**. External-group mapping via **identity/group-alias** (Entra **objectId** → Vault external group) is unchanged. (HashiCorp Developer)

OIDC auth-code + PKCE flow (for your architecture/flow diagrams), exact ordering:

1. Client (CLI/UI) calls **auth/oidc/oidc/auth_url** with **redirect_uri**, **role**, and a generated **nonce**. Vault returns the provider **auth_url** containing **client_id**, **nonce**, **state**, **redirect_uri**, **response_type=code**, **scope**, and (for PKCE) **code_challenge** + **code_challenge_method=S256**.
2. User authenticates at Entra; Entra redirects back to the **redirect_uri** with **code** + **state**.

3. Client calls `auth/oidc/oidc/callback` with `state`, `nonce`, `code`.
4. Vault exchanges `code` (with PKCE `code_verifier`) for the ID token at Entra's token endpoint.
5. Vault validates the ID token signature (JWKS), `iss`, `aud` vs `bound_audiences`, `nonce`, and `bound_claims`.
6. Vault maps `groups_claim`/`fetch_groups` to external group aliases, resolves policies, and issues a Vault token.

4. Policies & authorization (HEAVY)

Capability set in 2.0 CE: `create`, `read`, `update`, `patch`, `delete`, `list`, `sudo`, `deny`, `recover`, `subscribe`. The `recover` capability (snapshot single-secret recovery authorization) and `subscribe` (event subscriptions, with `subscribe_event_types`) are both present in CE. **No new capability was added in 2.0.0 beyond the 1.21 set** — `recover` arrived in 1.21. (Note: actually *recovering* a secret from a loaded snapshot is an Enterprise workflow; the ACL capability exists in CE.) [HashiCorp Help Center](#)

BREAKING (CE, 2.0.0) — wildcards/globs banned in rendered identity-template output: Vault now returns `permission denied` if a templated policy renders a `*` or `+` into the path. This is the change most likely to break your IdP setup if you use identity templating. The legitimate pattern is unaffected — the glob must be *literal* in the policy, not produced by the template:

[HashiCorp Developer](#) [HashiCorp Developer](#)

```
hcl

# STILL VALID (glob is literal, template only fills a path segment):
path "secret/data/{{identity.entity.id}}/*" {
  capabilities = ["create", "read", "update", "patch", "delete"]
}

# NOW DENIED if the metadata value itself renders to contain * or +:
path "secret/data/{{identity.entity.aliases.auth_oidc_xxxx.metadata.team}}/*" { ... }
# -> fails only if .metadata.team resolves to a string containing a glob/wildcard
```

Audit any policy where a templated attribute could contain user-controlled `*`/`+`.

BREAKING (CE, 2.0.0) — non-canonical path handling: In 1.21.x Vault *rejected* paths containing `//`, `/./`, `/../`; in 2.0.0 core "rejects paths that are not canonical" and then (per CHANGELOG) **redirects** non-canonicalized paths to a cleaned path instead of rejecting. Either way, clients (your FastAPI service, any hand-built API URLs) that accidentally emit double slashes will see different behavior — normalize paths in your client. [GitHub + 2](#)

LIST-with-trailing-slash deny fix (CE): A `deny` on `path "kv/*"` could previously be bypassed for `LIST kv/private/` if a broader allow `path "kv/*"` also existed. This was corrected (and re-

fixed in 2.0.3). **Policies that relied on the old (buggy) behavior may now be denied** — re-test least-privilege LIST policies. (GitHub) (GitHub)

(allowed_parameters)/(denied_parameters) **list matching**: the 1.21.0 change (each list element *and* the whole list are checked; VAULT_LEGACY_EXACT_MATCHING_ON_LIST restores old behavior) carries into 2.0. 2.0.0 adds a warning about list comparison. (HashiCorp Developer) (githubusercontent)

Visual policy generator (build ACL snippets in the GUI) is **Enterprise UI**; CE gets only the "ACL Policies intro" onboarding page. (vault <cmd> -output-policy) remains the CE way to derive required capabilities. (HashiCorp Developer)

5. KV & secrets engines (HEAVY)

- **KV v2**: plugin updated to v0.26.2 in 2.0.0; **no schema or behavior break**. Data/metadata path split unchanged. UI bug fixes for KV v2 metadata list without trailing slash and KV v1 edit-without-read regression. (githubusercontent) (githubusercontent)
- **No KV deprecations or removals in 2.0.0** (the deprecation table is "None/None").
- **New secrets engines are Enterprise**: OS/local-accounts (secrets/os), Linux credential rotation), PKI External CA (ACME to public CAs). Neither is CE.
- **Transit (your auto-unseal + EaaS)**: CE, unchanged operationally; 2.0 boosts random-byte API limits and adds PRNG-seeded random bytes; envelope-encryption workflow is highlighted (Transit protecting DEKs) and remains CE. (GitHub) (githubusercontent)
- **PKI (CE parts)**: (sign-verbatim) now honors basic-constraints in CSRs; (sign-intermediate) (max_path_length) restricted by signing CA; glob DNS names allowed in (alt_names); various CE bug fixes. SCEP/EST/CMPv2/External-CA remain Enterprise. (GitHub +2 +2)
- **Database engines**: many plugin bumps; MSSQL lease-revocation fix (no longer needs sysadmin). LDAP/AD static-role rotation moving to the central Rotation Manager is **Enterprise**. (HashiCorp Developer + 2)

6. Integrated Storage (Raft) + Transit auto-unseal operational story (HEAVY)

No Raft on-disk/schema change is documented for 2.0.0. The autopilot machinery (server stabilization, dead-server cleanup, State API) remains CE; **automated upgrade migration** ((autopilot_upgrade_version)) and **redundancy zones remain Enterprise-only** (confirmed: (disable_upgrade_migration) is labeled Enterprise-only). So your single-node/CE Docker Compose cluster upgrades by manual binary swap + unseal, not autopilot. (HashiCorp Developer) (Enclave)

Container/mlock behavior — the operationally important change for you:

- 1.21.x: official image had (cap_ipc_lock) set at build time (toggled across 1.21.6/1.21.7); ran as non-root (vault) user.
- 2.0.1: image *requires* (IPC_LOCK) capability (set at build time) — add (cap_add: [IPC_LOCK]) or run as root, else container fails to start. (hashicorp)

- **2.0.2+ (final state):** `cap_ipc_lock` removed at build time. Vault in the container can no longer `mlock()`. You **MUST** set `disable_mlock = true` and should run on hosts with swap disabled or encrypted.

Because the model flipped three times, **pin a specific patch**. Recommended target: **2.0.3** with `disable_mlock = true`.

Transit auto-unseal + recovery keys (unchanged): With Transit auto-unseal, `vault operator init` yields **recovery keys** (not unseal keys); recovery keys are an authorization mechanism only (they cannot decrypt the root key, so they cannot unseal if the Transit backend is down). Rekey recovery keys with `vault operator rekey -target=recovery`. The 2.0.0 authentication change means `sys/rekey` (incl. `-target=recovery`) and `sys/generate-root` **now require a valid Vault token** in addition to recovery-key fragments — if you automated recovery-key rekeying or root-token regeneration with an unauthenticated script, it will now fail unless you supply a token or set `enable_unauthenticated_access` (not recommended). Snapshots: manual `vault operator raft snapshot save/restore` is CE; automated snapshots are Enterprise. (Medium + 2)

7. AI-agent / OAuth resource server / SCIM / MCP (document fully; mark availability)

These were flagged in prior research as Beta/Enterprise — confirmed.

(a) AI-agent support + OAuth resource server — BETA/ENTERPRISE, landed 2.0.0. Verbatim from the GitHub CHANGELOG (2.0.0): "AI Agent Support (Beta/Enterprise): Adds beta support for first-class AI agents. Adds an Agent Registry to register agents, and adds support for using Vault as an OAuth resource server for registered agent entities. When configured, allows OAuth 2.0 JWTs to be used to directly authorize requests to Vault, without needing a Vault token."

HashiCorp's blog describes the model: an **agent registry** (register/manage agents separately from human and NHI identities), **ceiling policies + per-request (ephemeral) authorization** built on the OAuth 2.0 Rich Authorization Requests (RAR) spec via the `authorization_details` JWT claim, and delegation/on-behalf-of (OBO) tracking. Authorized actions = intersection of human policy $\cap$ agent policy $\cap$ ceiling policy $\cap$ per-request RAR details. Telemetry counters exist for

`vault.oauth.resource.server.config.count` and

`vault.agentregistry.agent.registrations.with_rar_on.count`. **None of this runs on CE.**

HashiCorp's release notes separately list "Native support for AI agents: Available to all customers in public beta" — i.e., the *beta* gating is broad but it is still an Enterprise-tier capability, not a CE feature. (GitHub + 5)

(b) OAuth resource-server mode (RFC 8707 resource indicators / RFC 9728 protected-resource metadata): This is the standards layer underpinning (a). RFC 8707 lets a client put a `resource` param so the AS sets the token `aud`; RFC 9728 publishes `/.well-known/oauth-protected-resource` so clients discover the AS. Vault 2.0's "OAuth resource server" feature lets it *accept* OAuth 2.0 JWTs directly (validating `aud`/scopes) — but **Enterprise/Beta only**. On CE today, you cannot turn Vault into an RFC-8707/9728 OAuth resource server; you continue to authenticate via `auth/jwt`/`auth/oidc` and to *issue* tokens via `identity/oidc`. If you need an MCP-style protected-

resource pattern on CE, you build it in your FastAPI layer (serve PRM yourself; validate `aud` against your resource URI), using Vault's `identity/oidc` as the issuer — exactly the A2A/OIDC pattern HashiCorp documents in its CE-compatible tutorials (e.g., the A2A-OIDC learn repo where `identity/oidc/client` issues `client_id`/`client_secret`, `id_token_ttl`, `access_token_ttl` for an OAuth authorization-code flow). [Medium](#) [RockB](#)

(c) SCIM 2.0 server — BETA/ENTERPRISE, landed 2.0.0. *"SCIM 2.0 Identity Provisioning Beta (Beta/Enterprise): Adds beta support for Vault to act as a SCIM 2.0 server, allowing external management of Vault entities, aliases and groups."* Integrates with Okta/SailPoint group push. Known issue in 2.0.0: Okta group-member *removal* (SCIM PATCH) isn't honored (fixed 2.0.1). **Not CE.** On CE you keep syncing Entra groups via OIDC `groups_claim`/`fetch_groups` + `identity/group-alias`. [GitHub + 2](#)

(d) MCP (Model Context Protocol) auth: Two distinct things. (i) The standalone **Vault MCP server** (`hashicorp/vault-mcp-server`, separate binary/Docker image) is **public beta**, intended for **local use only**, and talks to your Vault via an ordinary `VAULT_TOKEN` over the normal API — so it **works against CE today** for natural-language KV/PKI/mount operations (stdio or StreamableHTTP transport; set `MCP_ALLOWED_ORIGINS`, use a least-privilege token, keep TLS). It is *not* a Vault server feature and does not gate on edition. (ii) Using Vault itself as the OAuth resource server for MCP-style audience-bound tokens is the Enterprise/Beta feature in (a)/(b). Example local config: [HashiCorp Developer + 2](#)

```
json

{ "mcp": { "servers": { "vault": {
  "command": "docker",
  "args": ["run", "-i", "--rm", "-e", "VAULT_ADDR", "-e", "VAULT_TOKEN", "hashicorp/vault-mcp-server"],
  "env": { "VAULT_ADDR": "https://vault.example.com:8200", "VAULT_TOKEN": "<least-privilege-token>" },
  "type": "stdio"
}}}

```

8. Lighter-touch areas (changes noted, not exhaustive)

- **Kubernetes/AWS/Azure/GCP auth:** plugin bumps (`auth/azure` v0.24.0, `auth/gcp` v0.23.1, `auth/kubernetes` v0.24.1). Azure **auth method** config-over-env precedence is the one breaking change. WIF fixes for GCP. All CE. [GitHub + 2](#)
- **GitHub/LDAP auth:** LDAP login now requires non-empty passwords (CE hardening); LDAP *secrets* self-managed static roles are Enterprise. [githubusercontent](#)
- **Replication, namespaces, Sentinel:** Enterprise, unchanged edition status (see OpenBao note below).
- **Identity:** `identity/entity/merge` now requires `sudo`; duplicate/dangling entity-alias integrity repair; two new alias fields (`external_id`, `issuer`) reserved for a future feature.

9. OpenBao divergence (CE alternative context)

OpenBao 2.5.0 (Feb 4, 2026, Linux Foundation/OpenSSF, MPL-2.0, API-compatible fork from Vault 1.14) now ships several things that are Enterprise-gated in Vault 2.0 **for free**: **namespaces** ("now available in the open source version"), **horizontal read scalability** (standby read-serving, akin to Performance Standby Nodes, "Added in OpenBao 2.5.0 as of 4.02.2026"), PKCS#11/HSM auto-unseal, and the Transform engine. Note OpenBao independently hardened the same rekey DoS class — 2.5.0 ships a breaking default of `(disable_unauthed_rekey_endpoints = true)`, conceptually parallel to Vault 2.0's authenticated-rekey change. Vault Enterprise still wins on Performance/DR replication, Sentinel, FIPS 140-3 builds, HCP managed offerings, and the new AI-agent/SCIM/SPIFFE/Secret-Sync features. For a CE-only IdP self-hosted, the decision is governance/licence (BSL vs MPL) — not day-to-day features. Community benchmarks on default dev-server configs are not apples-to-apples and shouldn't be treated as production guidance.

(bespinian) (Jorijn)

Migration Runbook: Vault 1.21.x CE → 2.0.x CE (Docker Compose + Raft + Transit auto-unseal + TLS)

Supported path & version skew: Direct in-place upgrade **1.21.x → 2.0.x is supported; no intermediate hop required; no documented hard minimum version.** There is **no dedicated "Upgrade to 2.0.x" page** — version-specific guidance is in "Important changes." Rollback is **not** automatic.

Target selection: Pin **2.0.3** (latest CE patch as of June 17, 2026) to get the final container capability model, the LIST-deny re-fix, RSA cap, and constant-time recovery-token comparison in one shot. Note that 2.0.1 CE had incomplete artifact availability and was superseded by 2.0.2 — do not stop on 2.0.1.

Pre-flight (do all before touching the binary):

1. **Back up:** `(vault operator raft snapshot save pre-2.0.snap)`; copy your data volume; copy `(config.hcl)` and TLS material. Vault makes **no backward-compatibility guarantee for the data store** and the upgrade may mutate it. (HashiCorp Developer)
2. **Inventory breaking changes against your stack:**
 - Any client emitting non-canonical paths `((//), (/./))` → fix client.
 - Any **templated policy** that could render a `(*)/(+)` → rewrite (literal globs only).
 - Any **least-privilege LIST policy** relying on the old trailing-slash deny bug → re-test.
 - Any **unauthenticated automation** of `(sys/rekey)/(sys/generate-root)/recovery-rekey` → add a Vault token (or, last resort, `(enable_unauthenticated_access)`).

- Any **Azure auth method** relying on `(AZURE_*)` env overriding stored config → reconcile.
- Any **RSA > 8192-bit** keys in PKI/Transit → rotate before upgrade (2.0.2+).

3. Config diff (before → after):

hcl

```
# BEFORE (1.21.x), Docker Compose container
storage "raft" {
  path      = "/vault/data"
  node_id   = "vault-1"
}
listener "tcp" {
  address       = "0.0.0.0:8200"
  tls_cert_file = "/vault/tls/tls.crt"
  tls_key_file  = "/vault/tls/tls.key"
}
seal "transit" {
  address      = "https://transit-vault:8200"
  key_name     = "autounseal"
  mount_path   = "transit/"
}
# (disable_mlock may be present or absent on 1.21)
```

hcl

```
# AFTER (2.0.3) – only real change is making disable_mlock explicit
disable_mlock = true           # REQUIRED on 2.0.2+ containers (no cap_ipc_lock)
storage "raft" {
  path      = "/vault/data"
  node_id   = "vault-1"
}
listener "tcp" {
  address       = "0.0.0.0:8200"
  tls_cert_file = "/vault/tls/tls.crt"
  tls_key_file  = "/vault/tls/tls.key"
}
seal "transit" {
  address      = "https://transit-vault:8200"
  key_name     = "autounseal"
  mount_path   = "transit/"
}
```

yaml

```
# docker-compose.yml: REMOVE the IPC_LOCK cap_add on 2.0.2+ (no longer used);
# ensure swap is disabled/encrypted on the host since mlock is off.
services:
  vault:
    image: hashicorp/vault:2.0.3      # was hashicorp/vault:1.21.x
    # cap_add: ["IPC_LOCK"]           # <- remove on 2.0.2+; harmless but unused
    # If you briefly run 2.0.1, you MUST keep cap_add: [IPC_LOCK]
```

Cutover (single node / CE; for multi-node, do standbys first, active last): 4. Stop the old container (`SIGTERM`) (`docker compose stop vault`). 5. Swap the image tag to `2.0.3`, apply the `disable_mlock = true` config, start the container. 6. **Unseal:** With Transit auto-unseal, the node unseals automatically against the Transit backend — **no recovery keys needed for a normal version upgrade** (recovery keys are only for rekey/root-regeneration, which now also need a Vault token). Confirm: `vault status` shows `Sealed false`, `Seal Type transit`, `Recovery Seal Type shamir`, and `Version 2.0.3`. 7. Smoke-test the IdP path: `vault login -method=oidc role=reader`; verify group→policy mapping; verify your FastAPI/React app's OIDC-provider JWKS (`identity/oidc/provider/<name>/.well-known/keys`) and RS256 token issuance still validate. 8. Re-run any policy that touches templated paths and LIST-with-trailing-slash to confirm no new `permission denied`.

Downtime & rollback:

- **Downtime:** seconds-to-minutes for a single CE node (container restart + auto-unseal). A *version* upgrade needs **no** seal migration, so the "must take the whole cluster down" rule (which applies to *seal-type* migration, not version upgrades) does not apply here. (HashiCorp Developer)
- **Rollback: not automatic.** To revert: stop 2.0.x, reinstall the 1.21.x binary/image, AND restore the pre-upgrade snapshot/data volume (downgrading the binary alone is unsafe because upgrades may have mutated on-disk structures). Keep `pre-2.0.snap` until you've validated 2.0.x in production for a few days. (HashiCorp Developer)

Migration sequence (for your diagram), exact order: back up → inventory breaking changes → edit config (`disable_mlock=true`, image tag) → stop node → start 2.0.3 → auto-unseal via Transit → `vault status` version check → OIDC/policy smoke tests → retire snapshot after soak.

Pros / Cons by functional area (CE lens)

OIDC/JWT IdP — *Pros:* unchanged APIs, multi-JWKS cache, Entra >200-group `fetch_groups`, CVE-2026-5807 fixed. *Cons:* none specific; the OAuth-resource-server/SCIM modernization is Enterprise, so CE group sync stays "OIDC claim + group-alias."

Policies/authz — *Pros*: genuine security fixes (LIST deny, canonical paths). *Cons*: two real breaking changes (templated globs, LIST deny) can silently change access — must test.

KV/secrets — *Pros*: no breaks, plugin fixes. *Cons*: all *new* engines (OS, External CA) are Enterprise.

Raft + Transit auto-unseal — *Pros*: no schema change, simple version upgrade, no seal migration. *Cons*: container mlock model churned across patches (pin a version); automated upgrades/snapshots still Enterprise.

AI/agentic — *Pros*: clear roadmap; MCP server usable on CE locally. *Cons*: the actual agent-identity/OAuth-resource-server/SCIM features are Enterprise/Beta — for CE you implement OBO/PRM yourself in FastAPI on top of `identity/oidc`.

NEW in 2.0 / CHANGED / DEPRECATED / REMOVED

NEW (CE): multi-JWKS kid cache (`auth/jwt`); `max_token_header_size` listener option (default 8 KB, `-1` to disable); non-canonical path redirect; constant-time recovery-token comparison (2.0.3); `auth/radius case_insensitive_names` (2.0.3); reserved identity-alias fields `external_id`/`issuer`.

NEW (Enterprise/Beta): AI-agent registry + OAuth resource server (RAR, Beta/Ent); SCIM 2.0 server (Beta/Ent); SPIFFE JWT-SVID (Ent); Secret Sync via WIF (Ent); PKI External CA/ACME (Ent); OS/local-accounts engine (Ent); rotation policies + LDAP self-managed static roles (Ent); visual policy generator, namespace wizard, billing dashboard (Ent UI); IBM PAO license support (`license_entitlement`). `HashiCorp Developer +2`

CHANGED / BREAKING (CE): `sys/rekey`, `sys/generate-root`, DR generate-operation-token now authenticated (2.0.0); Azure auth config-over-env precedence (2.0.0); wildcards/globs denied in rendered templated policies (2.0.0); non-canonical paths rejected→redirected (2.0.0); container `cap_ipc_lock` removed → `disable_mlock=true` required (2.0.2); RSA ≤8192 bits (2.0.2); LIST trailing-slash deny enforced (re-fixed 2.0.3); `identity/entity/merge` needs `sudo`; `sdk/helpers/docker`→moby (build-level breaking). `GitHub`

DEPRECATED / REMOVED: None for 2.0.0 (official deprecation table: "None / None"). UI: secrets-engine URL path renamed `/secrets`→`/secrets-engines`; bulk-delete of secrets engines removed from list view (cosmetic/UI). `GitHub` `githubusercontent`

Recommendations

1. **Upgrade, and target 2.0.3 specifically.** You're exposed to CVE-2026-5807 (unauth rekey/generate-root DoS) on any CE ≤1.21.4, and **there is no 1.x CE backport** — the only CE fix is the 2.0.0 line. 2.0.3 also gives you the settled container model + LIST-deny re-fix.

Threshold to act sooner: if your Vault API is reachable beyond a trusted network, treat this as high priority now. (Zeropath)

2. **Before cutover, run the three CE-breaking tests:** (a) grep policies for templated paths that could render a glob; (b) re-test every least-privilege LIST policy; (c) confirm no automation hits (sys/rekey)/(sys/generate-root) unauthenticated. Fix all three in a staging clone restored from (pre-2.0.snap) in an isolated network.
 3. **Set (disable_mlock = true) and drop the (IPC_LOCK) cap_add (2.0.2+),** and ensure the host has swap disabled or encrypted. Don't stop on intermediate 2.0.1 (its model needs (IPC_LOCK) and CE artifacts were incomplete); jump straight to 2.0.3.
 4. **Keep your IdP architecture as-is.** OIDC in (Entra) and OIDC out ((identity/oidc) RS256) stay CE. Adopt the **multi-JWKS cache** and, if you hit Entra group overage, switch to (fetch_groups) + (distributed_claim_access_token).
 5. **For agentic/MCP work on CE:** use the standalone Vault MCP server **locally only** with a least-privilege token for dev convenience; implement OAuth-resource-server/PRM (RFC 8707/9728) and OBO **in your FastAPI layer** using Vault's (identity/oidc) as issuer. Don't budget for the native agent-registry/SCIM features unless you move to Enterprise.
Threshold to reconsider Enterprise: if you need audited agent delegation/ceiling policies or IdP-driven SCIM provisioning at scale. (HashiCorp Developer)
 6. **If governance/licence (OSI-open, no IBM lock-in) outranks the new Enterprise features for you, evaluate OpenBao 2.5.0** — it gives free namespaces and standby read scaling and stays API-compatible. *Threshold:* only if you need namespaces/those features free, or your procurement requires an OSI licence; otherwise stay on Vault CE for the deeper ecosystem and first-party security cadence. (We The Flywheel)
 7. **Retain (pre-2.0.snap)** until 2.0.x has soaked in production for several days, since rollback requires a data restore, not just a binary swap.
-

Caveats & verification status

- **Confirmed against primary sources:** 2.0.0 GA date (April 14, 2026; GA blog April 13) and patch timeline (2.0.1 CE 2026-05-19, 2.0.2 June 5, 2.0.3 June 17); IBM acquisition completed Feb 27, 2025 (\$35/share, ~\$6.4B); SC2/IBM versioning; BSL 1.1 status; all CE breaking changes (authenticated rekey/generate-root, Azure precedence, templated-glob denial, canonical paths, IPC_LOCK/mlock across 2.0.0/2.0.1/2.0.2, RSA cap, LIST-deny re-fix in 2.0.3); CVE-2026-5807/HCSEC-2026-08 affecting CE ≤1.21.4 fixed only in 2.0.0; AI-agent/OAuth-resource-server, SCIM, SPIFFE, Secret-Sync, External-CA, OS engine all Enterprise/Beta; (auth/jwt) v0.26.1 + multi-JWKS cache (CE); Entra (fetch_groups); Vault MCP server beta usable on CE; OpenBao 2.5.0 feature set (incl. its breaking (disable_unauthed_rekey_endpoints=true) default).

- **Could not verify against a primary HashiCorp source:** a hard *minimum version* prerequisite before upgrading to 2.0.0 (none documented; direct 1.21.x→2.0.x is the supported path); the existence of a dedicated </vault/docs/upgrading/upgrade-to-2.0.x> page (none — guidance lives in "Important changes"); any Raft on-disk *schema* change in 2.0.0 (none documented — absence of evidence).
- **Inference (flagged):** the "no seal migration needed for a version upgrade" downtime claim is derived from the fact that 2.0 introduces no seal-type change and standard in-place upgrade semantics — verify in your own staging clone. The recommendation to skip 2.0.1 is operational judgment based on its transient `IPC_LOCK`-required model and incomplete CE artifacts.
- **Beta/forward-looking language:** HashiCorp's "AI agent" and SCIM features are explicitly labeled *beta* and "subject to change"; treat the RAR/agent-registry/OAuth-resource-server specifics as pre-GA and likely to evolve. The Vault MCP server is beta and "local use only." Because Vault 2.0 is recent, re-confirm any feature you depend on against the current CHANGELOG and "Important changes" page at upgrade time. [HashiCorp Developer](#)